1. Motivacija napadača

Da bi se procenio potreban nivo zaštite Mega Travel aplikacije potrebno je odrediti potencijalne napadače sistema, na koji način bi pristupili sistemu i koji su im ciljevi. Kako sistem koristi preko sto miliona korisnika i poseduje sedišta i filijale širom sveta, zadatak ne treba shvatiti olako.

Potencijalne klase napadača su:

Vrsta napadača	**Cilj**	**Nivo veštine**	**Pristup sistemu**
državno sponzorisani napadači	prikupljanje podataka o korsinicima, nadzor sistema	veoma visok	ranjivosti sistema, phishing, kompromitovanje zaposlenih
finansijski motivisani sajber kriminalci	novac, krađa informacija	srednji/visok	phishing, krađa naloga, sql injection, ranjivosti sistema
interni napadači	lična korist, novac, osveta	može da varira, ali imaju interni pristup	direktan
konkurentske kompanije	sticanje informacija o konkurenciji	neodređeno	ddos, sql injection, phishing

2. Imovina (Assets)

Imovina kompanije **MegaTravel** obuhvata sve resurse koji imaju vrednost za organizaciju i čija kompromitacija može dovesti do finansijskih gubitaka, narušavanja reputacije ili pravnih posledica.

U tabeli su opisane identifikovane imovine, njene inherentne izloženosti (ko ima pristup), bezbednosne ciljeve prema CIA modelu (poverljivost, integritet, dostupnost), kao i potencijalni uticaj u slučaju narušavanja ovih ciljeva.

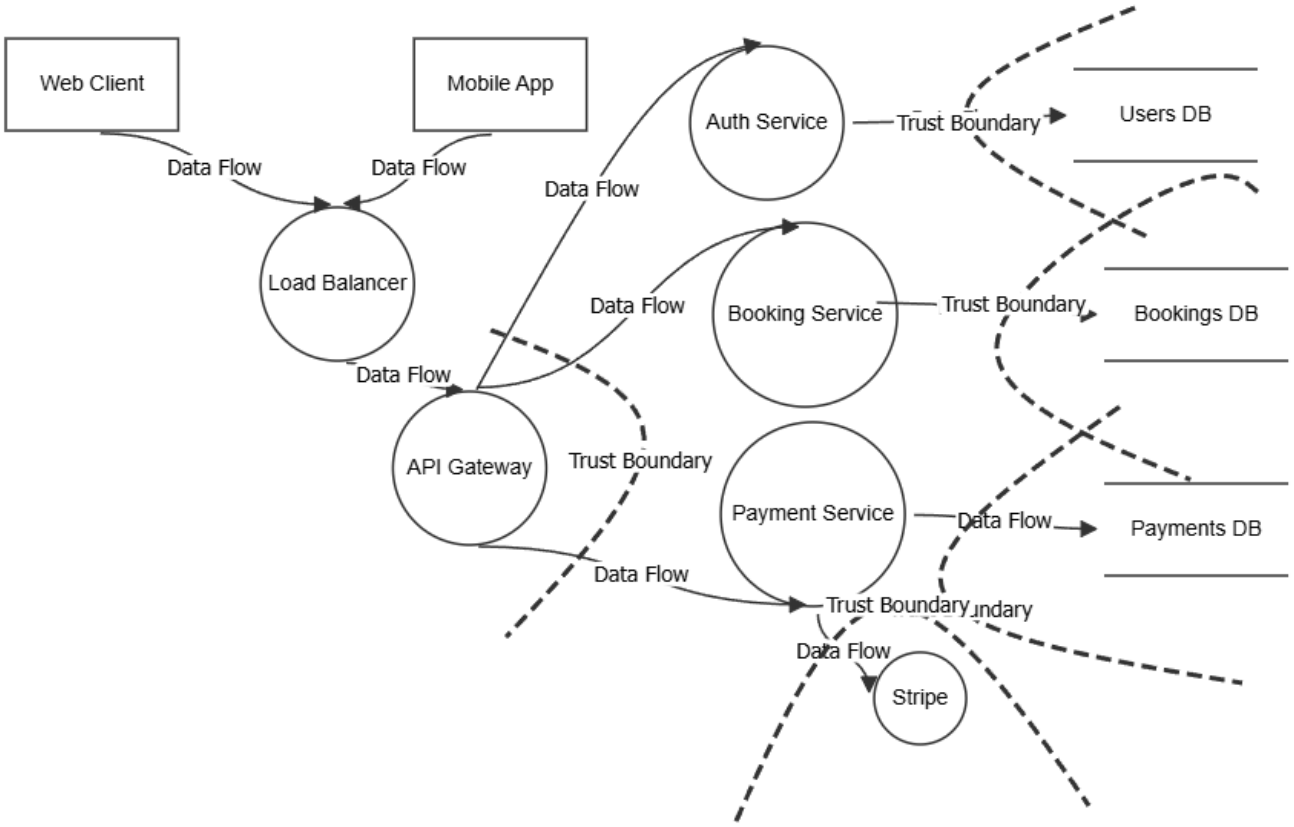
Imovina	Exposure (ko ima pristup)	CIA (poverljivost, integritet, dostupnost)	Impact
Lični podaci korisnika	korisnici (sopstveni podaci), backend, support, admini	C: visoka, I: srednja, A: srednja	pravne kazne, gubitak poverenja
Finansijski podaci	payment sistemi, backend, ograničen pristup	C: kritična, I: kritična, A: visoka	krađa novca, prevare, regulatorne kazne
Korisnički nalozi	korisnici, auth sistem	C: kritična, I: visoka, A: visoka	preuzimanje naloga, zloupotrebe
Rezervacije	korisnici, partneri, interni sistemi	C: srednja, I: kritična, A: visoka	pogrešne rezervacije, finansijski gubici
Infrastruktura	admini, DevOps, internet	C: visoka, I: kritična, A: kritična	pad sistema, gubitak prihoda
Poslovni podaci	interni timovi	C: visoka, I: visoka, A: srednja	gubitak konkurentske prednosti

3. Površina napada (Attack surface)

Akteri sistema su krajnji korisnici, administratori, zaposleni, partneri, email/sms servisi i admin/DevOps. Za svakog od njih postoji ulazna tačka:

Ulazna tačka	Akter	Tip pristupa	Potencijalni napadi
Web aplikacija (frontend)	Krajnji korisnici	Internet	XSS, SQL injection, brute force login
Mobilna aplikacija	Krajnji korisnici	Internet	reverse engineering, API abuse
Admin panel	Administratori	Internet / VPN	privilege escalation, credential theft
Interni sistemi	Zaposleni	Intranet	insider misuse, data leakage
API integracije	Partneri (hoteli, avio)	Internet (API)	API abuse, spoofing
Payment API	Payment sistemi	Internet	man-in-the-middle, fraud
Notifikacioni sistemi	Email/SMS servisi	Internet	phishing, spoofing
SSH / cloud pristup	DevOps/Admini	Internet / privatne mreže	brute force, key compromise

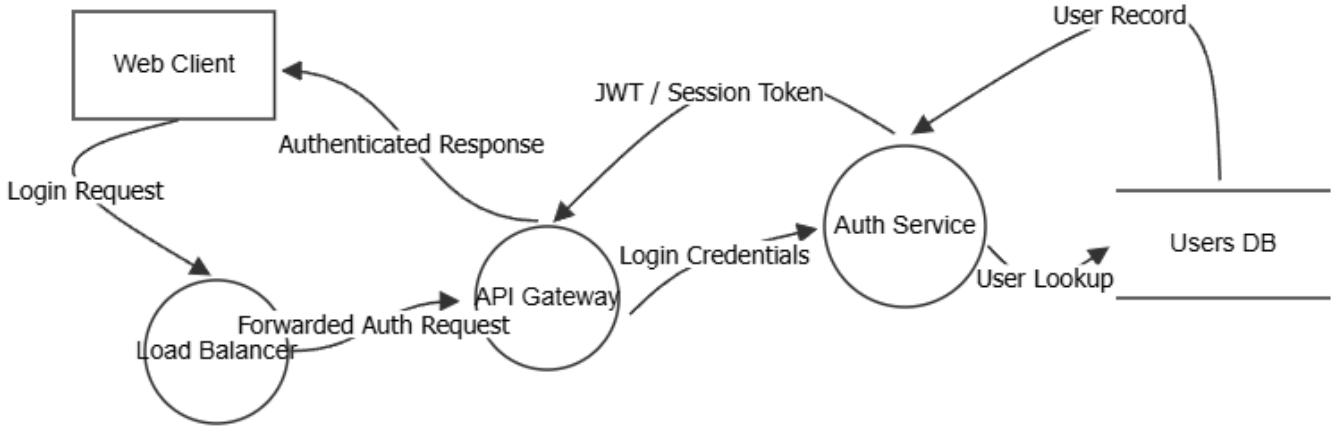
4. Data Flow Diagram



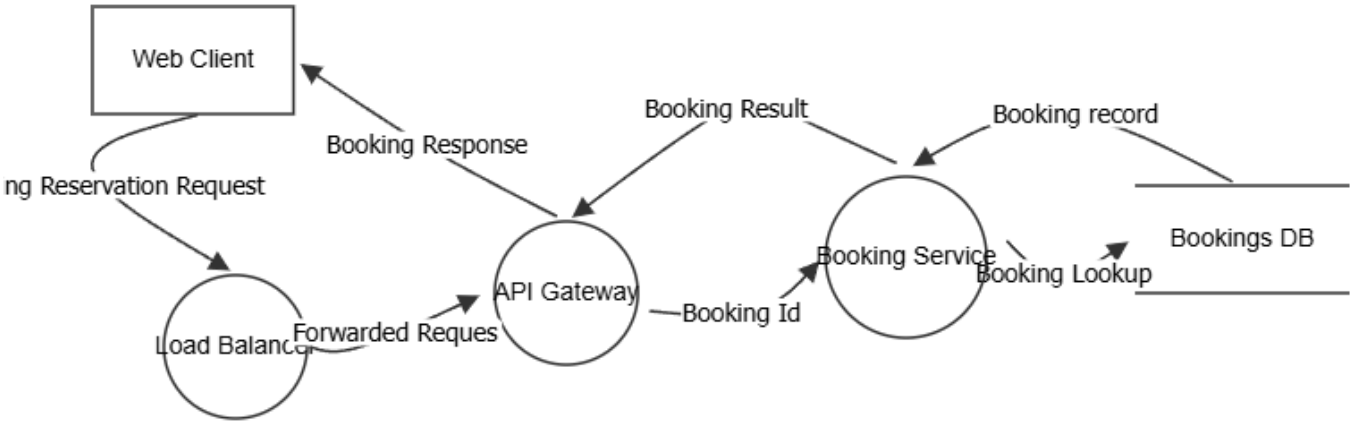
5. Analiza pretnji i mitigacije

5.1 Dijagrami toka podataka

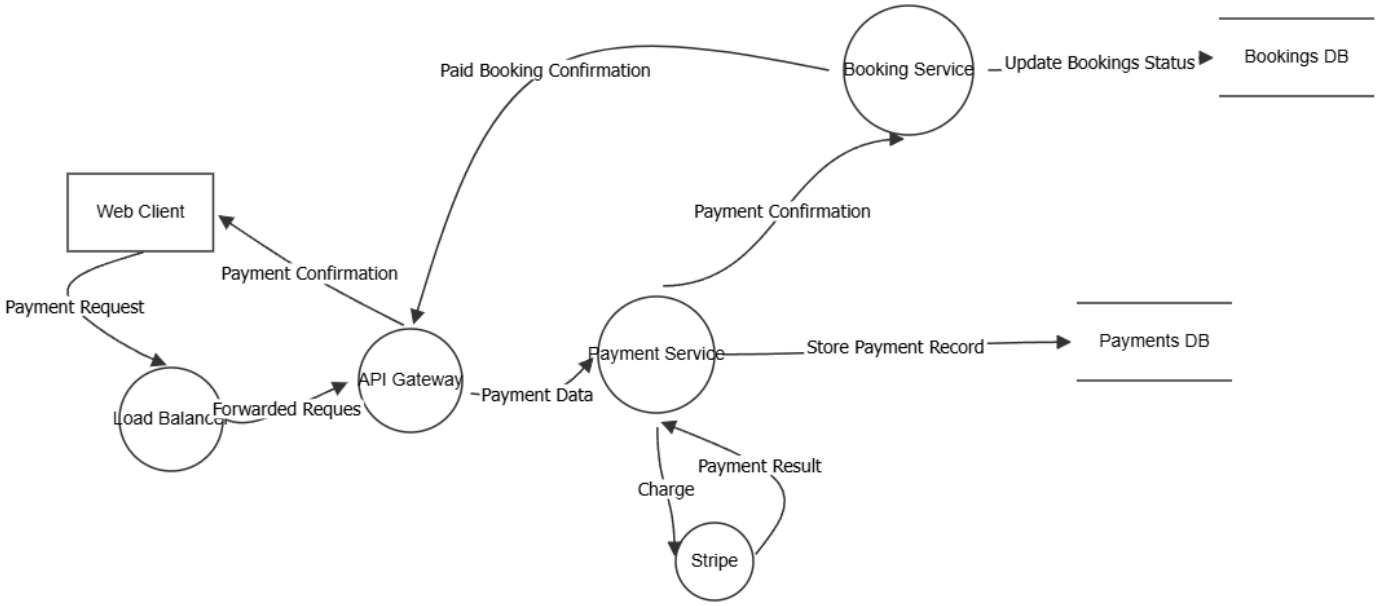
5.1.1 Login Data flow



5.1.2 Booking Reservation Data Flow



5.1.3 Payment Flow



5.2 STRIDE analiza pretnji i mitigacija

S - Spoofing (Lažno predstavljanje)

Napadački scenario	Pretnja / ranjivost	Mitigacija
Napadač se predstavlja kao korisnik	Krađa kredencijala (phishing)	MFA, edukacija korisnika
	Brute force napad	Rate limiting, CAPTCHA
	Slaba lozinka	Politika lozinki
Spoofing sistema (API / partner / payment)	Lažni API endpoint	TLS, validacija sertifikata
	Man-in-the-Middle napad	HTTPS, certificate pinning

T - Tampering (Izmena podataka)

Napadački scenario	Pretnja / Ranjivost	Mitigacija
Izmena podataka u toku komunikacije	MITM napad	TLS
	Manipulacija API zahtevom	Validacija inputa
Izmena podataka u sistemu	SQL Injection	Prepared statements
	Nevalidiran unos	Sanitizacija podataka

R - Repudiation (Poricanje akcije)

Napadački scenario	Pretnja / Ranjivost	Mitigacija
Korisnik negira izvršenu akciju	Ne postoje logovi	Audit logging
	Logovi nisu potpuni	Centralizovani log sistem
Nedostatak verifikacije akcija	Nema digitalnog potpisa	Digitalni potpisi, timestamp

I - Information Disclosure (Otkrivanje informacija)

Napadački scenario	Pretnja / Ranjivost	Mitigacija
Curenje podataka u komunikaciji	Nešifrovan saobraćaj	HTTPS
Curenje podataka iz baze	Nezaštićena baza	Encryption at rest
	Slaba kontrola pristupa	RBAC
Neautorizovan pristup podacima	Loša autentifikacija	Token-based auth

D - Denial of service (Onemogućavanje servisa)

Napadački scenario	Pretnja / Ranjivost	Mitigacija
Preopterećenje sistema	DDoS napad	Firewall, rate limiting
	Veliki broj zahteva	Load balancing
Pad servisa ili baze	Nedostatak resursa	Autoscaling
	Nema backup-a	Backup i failover

E - Elevation of Privilege (Eskalacija privilegija)

Napadački scenario	Pretnja / Ranjivost	Mitigacija
Neovlašćen pristup većim privilegijama	Loša autorizacija	RBAC
	IDOR napadi	Provera pristupa na backend-u
Pristup admin funkcijama	Nezaštićen admin panel	MFA, IP restrikcija